

NORTHLINK COMMUNICATIONS

Password Policy Review Document

Portfolio Project — GRC Policy Audit

Prepared by	Kapil Chaudhary — GRC Analyst (Portfolio)
Date	June 2026
Policy Reviewed	SANS Password Protection Policy (October 2022)
Framework Reference	ISO 27001:2022 — Annex A.9.4 (System and Application Access Control)
Organization	NorthLink Communications (Fictional Canadian ISP — Portfolio Simulation)
Review Purpose	Assess the effectiveness of the existing password policy against current security standards and NorthLink's operational environment

Overview

This policy review evaluates the SANS Password Protection Policy template as adopted by NorthLink Communications — a fictional Canadian ISP operating 145+ remote satellite sites across northern and rural Canada. The review assesses whether the policy is enforceable, current, and sufficient to address the password-related risks already identified in NorthLink's Cyber Risk Register (specifically RISK-001, RISK-005, and RISK-017). The audit examines not just whether controls exist, but whether they can be measured, enforced, and verified.

1. WHAT WORKS WELL

- Unique password requirement per account (Section 4.1.2) — explicitly prevents credential reuse across work systems, reducing lateral movement risk if one account is compromised.
- Password manager authorization (Section 4.1.3) — acknowledges that employees need practical tooling to manage multiple unique passwords, reducing the likelihood of insecure workarounds like sticky notes or browser-saved credentials.
- Prohibition on password sharing (Section 4.3.1) — clearly states passwords must not be shared with supervisors or coworkers, which is a critical control in NOC environments where shared credentials are common.
- No mandatory periodic expiration (Section 4.2.1) — aligned with current NIST SP 800-63B guidance, which recommends against forced calendar-based rotation as it leads to predictable password patterns (e.g. Password1! becoming Password2!).
- Application development controls (Section 4.4) — includes specific requirements for developers: no plain-text storage, no clear-text transmission, individual authentication over group accounts. These are foundational secure-coding requirements.
- Compliance and exception process (Section 5) — establishes an InfoSec team as the compliance owner with a defined exception approval process, providing a governance structure around enforcement.

2. WHAT IS MISSING — GAPS IDENTIFIED

GAP 1 — MFA is Advisory, Not Mandatory (Critical)

Sections 4.1.4 and 4.5.1 describe MFA as 'highly recommended' and 'highly encouraged.' In GRC and audit language, a recommendation is not a control — it cannot be measured, enforced, or verified. For privileged accounts with access to NorthLink's network management console and 145 satellite sites, MFA must be a mandatory, auditable requirement. The current language creates no accountability if MFA is not deployed.

Direct link to Risk Register: RISK-001 (Unauthorized access to network management console, Risk Score 20, Critical).

GAP 2 — No Single Enforced Password Manager (High)

Section 4.1.3 permits use of 'authorized, approved password managers' without defining which specific tool is approved or how approval is granted. This creates inconsistency across the organization — different staff may use different tools, creating fragmented visibility and support challenges. A single organizationally-provisioned password manager with centralized admin oversight is the appropriate control.

Direct link to Risk Register: RISK-017 (Weak password policy, no organization-wide password manager, Risk Score 25, Critical).

GAP 3 — No Event-Based Password Rotation Triggers Defined (High)

Section 4.2.1 correctly removes mandatory periodic rotation, but provides no specific triggers for when password changes ARE required. The policy should define explicit events that mandate immediate rotation: confirmed or suspected compromise, employee role change, employee offboarding, system security incident, or third-party credential exposure. Without defined triggers, staff have no clear guidance on when to act proactively.

Direct link to Risk Register: RISK-008 (Insider threat — terminated employee VPN credentials active, Risk Score 12, High).

GAP 4 — No Hashing Algorithm Specification (High)

Section 4.4.2 states applications must not store passwords in clear text or in any 'easily reversible form' — but does not specify which hashing algorithm must be used. This gap leaves developers without a clear standard. Acceptable algorithms include bcrypt, Argon2, or PBKDF2 with appropriate salt rounds. MD5 and SHA-1 are reversible via rainbow tables and must be explicitly prohibited. The absence of this specification is particularly relevant given NorthLink's legacy billing system (RISK-012) which was found to be storing credentials in plain text.

Direct link to Risk Register: RISK-012 (Legacy billing system with plain-text data storage, Risk Score 25, Critical).

GAP 5 — No Password Complexity or Minimum Length Standard (Medium)

The policy references 'Password Construction Guidelines' in Section 4.1.1 and Section 6 but does not include or attach those guidelines. The policy therefore has no standalone definition of what constitutes a valid password — no minimum character length, no complexity requirements, no prohibited patterns. Any audit or compliance check against this policy alone would be unable to verify whether password standards are being met.

Direct link to Risk Register: RISK-017 (30% of employees found using passwords from public breach databases).

3. RECOMMENDED IMPROVEMENTS

#	Gap	Recommended Action	Priority	ISO 27001 Ref
1	MFA advisory not mandatory	Revise Section 4.1.4 and 4.5.1 to state MFA is MANDATORY for all privileged accounts and REQUIRED for all remote access. Define enforcement mechanism and audit cadence.	Critical	A.9.4.2
2	No single mandated password manager	Specify a single organizationally-provisioned password manager (e.g. Bitwarden for Business, 1Password Teams) with centralized IT admin visibility. Mandate its use for all staff within 90 days.	High	A.9.4.3
3	No event-based rotation triggers	Add Section 4.2.2 defining mandatory password change triggers: confirmed/suspected compromise, role change, offboarding, security incident, or third-party credential exposure.	High	A.9.2.6
4	No hashing algorithm standard	Amend Section 4.4.2 to explicitly mandate use of bcrypt, Argon2, or PBKDF2 for password storage. Explicitly prohibit MD5 and SHA-1. Include minimum salt rounds requirement.	High	A.10.1.1
5	Password construction guidelines not included	Embed or append the Password Construction Guidelines directly into this policy document. Minimum: 12 characters, complexity requirements, prohibition on dictionary words and sequential patterns.	Medium	A.9.4.3

Audit Conclusion

The SANS Password Protection Policy provides a solid structural foundation and is well-aligned with current NIST SP 800-63B guidance on avoiding forced rotation. However, in its current form it is insufficient for NorthLink Communications' operational environment. Three of the five identified gaps — MFA not mandatory, no hashing standard, and missing password construction guidelines — represent Critical to High-severity control weaknesses that directly correspond to risks already identified in NorthLink's Cyber Risk Register. These gaps should be remediated before this policy is considered audit-ready for ISO 27001 certification.

The most urgent single action is reclassifying MFA from 'recommended' to 'mandatory' for privileged accounts. This change requires no new technology — only a policy revision and enforcement commitment — and directly addresses the highest-risk access control gap in NorthLink's current posture.